

CONFIDENTIAL — MANAGEMENT USE ONLY

INFORMATION TECHNOLOGY RISK REGISTER

EXECUTIVE SUMMARY REPORT

Prepared by: **Rushikesh Pandya** | Programme: MSc Enterprise & IT Security | Date: June 2026

1. Purpose of This Report

This Executive Summary presents the findings of an IT Risk Assessment conducted for the fictional University IT Department. The assessment identifies, evaluates, and prioritises **13 information technology risks** across four key domains: Cybersecurity, Operational, Compliance, and Third-party / Physical. The purpose of this report is to give senior management a clear, evidence-based picture of the university’s current risk exposure and to recommend concrete actions to reduce that exposure within defined timeframes.

! Who should read this report?

This report is intended for: IT Director, Head of IT Security, Data Protection Officer, University CIO, and any senior stakeholder responsible for approving IT investment or policy decisions.

2. Scope & Methodology

The assessment covered the following systems, processes, and environments:

- Student Information System (SIS), Learning Management System (LMS), email and cloud collaboration platforms
- Campus Wi-Fi infrastructure, research networks, and physical IT equipment across all faculties
- Compliance obligations including GDPR, software licensing, and external audit requirements
- Third-party dependencies including cloud service providers (Microsoft 365 / Google Workspace)

Risk Identification	Brainstorming across 4 domains: Cybersecurity, Operational, Compliance, and Third-party / Physical.
Scoring Model	Qualitative 1–5 scale for both Likelihood and Impact. Risk Score = Likelihood × Impact (max 25).
Risk Levels	Low: 1–5 Medium: 6–10 High: 11–19 Critical: 20–25
Treatment Framework	Mitigate, Accept, Transfer, or Avoid — based on score and organizational context.
Framework Alignment	Consistent with ISO 27001 risk management principles and NIST CSF 2.0 concepts.

3. Risk Landscape at a Glance

The assessment identified 13 risks. The distribution across severity levels is shown below.



The majority of risks (**7 out of 13**) are rated High, indicating that the university faces a significant and broad risk landscape that requires structured and prioritised remediation. One risk — phishing attacks on staff and students — is rated Critical, reflecting both the very high likelihood of occurrence and the serious impact a successful attack would have on university operations and data security.

4. Top 3 Priority Risks

The following risks scored highest in the assessment and require immediate management attention:

Risk ID	Risk Name	Score	Level	Priority Action
R-001	Phishing attack on staff / students	20	Critical	Mandatory phishing awareness training + simulated phishing tests
R-002	Ransomware attack on university servers	15	High	Network segmentation + automated patch management + offline backup tests
R-005	Unplanned IT system downtime	12	High	Define system SLAs + redundant hosting + outage runbook

! Why phishing is rated Critical — not ransomware?

Ransomware (R-002) has a higher potential impact (5/5) but a lower likelihood (3/5) because it requires a successful initial compromise. Phishing (R-001) has a likelihood of 5/5 — meaning it is almost certain to be attempted multiple times per year on a university with thousands of non-technical users. Its score of 20/25 places it firmly in the Critical band.

5. Risk Distribution by Category

Risks are distributed across four domains. Each domain has a distinct risk profile and requires a tailored response strategy.

Risk Category	No. of Risks	Highest Score	Key Concern
Cybersecurity	4	Critical (20)	Phishing & ransomware present the highest immediate threat
Operational	3	High (12)	System downtime during exams is operationally critical
Compliance	3	High (12)	GDPR non-compliance carries the highest legal & financial penalty
Third-party / Physical	3	High (12)	Cloud outage exposes lack of fallback communication plan

6. Top 5 Recommended Actions

The following five actions are recommended as the highest-priority steps to reduce the university's IT risk exposure. They are sequenced by urgency and are directly tied to the highest-scoring risks in the register.

#	Priority	Recommendation	Why It Matters	Owner
1	Immediate	Deploy phishing simulation & training program	R-001 scored Critical (20/25) — the highest risk in the entire register. Human error is the leading cause of security breaches globally.	Head of IT Security
2	Immediate	Enforce MFA across all university systems	MFA alone prevents over 99% of credential-based attacks. Applies directly to R-001, R-002, and R-003.	Head of IT Security
3	30 Days	Test and document backup recovery procedures	R-007 is rated High (12). Untested backups are worthless in a crisis — especially during a ransomware event (R-002).	IT Infrastructure Manager
4	30 Days	Complete GDPR data mapping exercise	R-008 carries legal exposure of up to €20M in fines. A data map is the first step to demonstrating compliance.	Data Protection Officer
5	60 Days	Implement network segmentation	Isolating critical systems limits the blast radius of R-002 (ransomware) and R-013 (Wi-Fi exploitation) significantly.	IT Infrastructure Manager

! Cost vs. benefit note

Actions 1 and 2 (phishing training and MFA) are low-cost, high-impact interventions. MFA alone is estimated to prevent over 99% of account compromise attacks — making it the single highest-return security investment available to the university.

7. Conclusion

The University IT Department faces a broad and credible set of IT risks, the most urgent of which involve human-targeted attacks (phishing and credential theft), infrastructure reliability, and regulatory compliance. The good news is that the two highest-impact mitigations — security awareness training and multi-factor authentication — are relatively inexpensive to implement and can dramatically reduce the university's overall risk exposure in the short term.

This risk register should be treated as a living document. It is recommended that it be reviewed and updated every six months, or immediately following any significant IT incident, system change, or change in regulatory requirements. All 13 risks, their scores, controls, and recommended actions are documented in full in the accompanying Risk Register (Excel).

8. Document Sign-Off

<i>rushikeshpandya</i>	MSc Enterprise & IT Security	07-06-2026
Prepared by	Programme	Date
Date: 07-06-2026	Date: 07-06-2026	Date: 07-06-2026

Disclaimer: This report was prepared by Rushikesh Pandya as part of an academic GRC portfolio project for the MSc Enterprise & IT Security programme. The organization, risks, and data presented are entirely fictional and are intended for educational purposes only. They do not represent the security posture of any real institution.